

CONTINUIDAD DEL NEGOCIO

BY NOVA TECH SOLUTIONS

1. INTRODUCCIÓN

Este documento define el procedimiento para identificar los procesos críticos de los Sistemas de Información de NovaTech Solutions y los riesgos a los que se ven expuestos con el fin de determinar planes de acción que permitan una correcta recuperación y continuidad de estos ante una interrupción.

2. OBJETIVO Y ALCANCE

Objetivo

Incrementar la certeza de que NovaTech Solutions mantenga la capacidad de recibir, gestionar y resolver solicitudes de clientes durante y después de un desastre u otra emergencia que afecte a los sistemas de información, minimizando el impacto reputacional, financiero, operativo y legal, mejorando la recuperación ordenada dentro de los Tiempos Máximos Tolerables.

Alcance

El plan abarca los procesos críticos que sostienen la operatividad y la propiedad intelectual de NovaTech Solutions ante eventos que comprometan su integridad, confidencialidad o disponibilidad. Esto incluye los procesos de Desarrollo y Mantenimiento de Software (Repositorios Git, Servidores CI/CD), Soporte y Atención al Cliente (Sistema CRM, Base de Datos de clientes), y la infraestructura subyacente en la nube, involucrando directamente al personal operativo, técnico y administrativo.

3. ANALISIS BIA

Análisis de los procesos

Procesos de negocio	Actividades	Activos Relacionados	Responsable
Desarrollo y mantenimiento de software	Desarrollo de plataformas web, mantenimiento de aplicaciones, gestión de repositorios de código	Repositorios de código (Git), Servidores de integración continua, Servidores en la nube (ambientes)	Atención a Clientes
Soporte y atención al cliente	Soporte técnico, gestión de solicitudes, manejo de información de clientes	Sistemas CRM, Base de datos de clientes, Servidores en la nube	Desarrollo de Software
Gestión de datos personales y privacidad	Gestión de datos de empleados	Base de datos de clientes, Datos personales de empleados (no incluido en los 4 activos críticos iniciales, pero sí en inventario)	Administración / RR.HH
Gestión financiera y contractual	Facturación, contratos, pagos,	Contratos legales (documentos), Servidores en la nube (para sistemas de facturación)	Administración

Análisis de Impacto ante la interrupción del proceso

Tomando de referencia el análisis de riesgos de la fase 3, se calcula el nivel de impacto en cada área si el proceso determinado se interrumpe

Procesos de negocio	Impacto Reputacional	Impacto Financiero	Impacto Operativo	Impacto Legal
Desarrollo y mantenimiento de software	Medio – El retraso continuo en entregas y la inestabilidad del código afectan la percepción de confiabilidad; puede ocasionar pérdida del 15 % al 50 % de clientes si se vuelve recurrente.	Medio – Reducción de ingresos por proyectos detenidos o entregas tardías (15 % - 45 % de ingresos mensuales), incremento de costos operativos (40 % - 100 %).	Alto – Los desarrolladores quedan inactivos. Cualquier interrupción superior a 2 horas del repositorio bloquea por completo el avance de todos los proyectos.	Medio – Riesgo de demandas por incumplimiento de contratos de desarrollo (1.5 – 5 millones de pesos). Si hubiera filtración de código fuente, el impacto legal aumentaría a Alto.
Soporte y atención al cliente	Alto – La interrupción prolongada (más de 4 h) genera pérdida masiva de confianza, abandono de clientes, frustración y	Medio – Posible pérdida de ingresos por cancelación de contratos y penalizaciones (entre 15 % y 45 % de ingresos mensuales).	Alto – Paralización total del soporte técnico y gestión de solicitudes. La caída del servicio por más de 12 horas	Medio – Incumplimiento de acuerdos de nivel de servicio (SLA) con posibles demandas contractuales de entre 1.5 y 5 millones de pesos. El

	retrasos en proyectos.		implicaría un aumento de carga laboral superior al 80 %.	tratamiento de datos personales de clientes eleva el riesgo regulatorio.
Gestión de datos personales y privacidad	Bajo – Una filtración interna de expedientes no suele atraer atención masiva, y la pérdida de confianza se limita al ámbito laboral.	Bajo – La indisponibilidad no genera pérdida significativa de ingresos.	Bajo – La nómina o administración de personal puede retrasarse unos días sin afectar los servicios al cliente. El aumento de horas de trabajo es menor al 30 %.	Alto – La violación de la LFPDPPP puede acarrear amonestaciones superiores a 10 millones de pesos e investigaciones de alto perfil por parte de la autoridad.
Gestión financiera y contractual	Bajo – Las actividades administrativas internas no son visibles para los clientes, así que la interrupción casi no daña la reputación.	Medio – La imposibilidad de facturar y gestionar pagos puede causar pérdidas temporales de ingresos, pero dentro del rango bajo-medio (menos del 15 %).	Bajo – El personal administrativo puede operar manualmente por cortos periodos; el impacto en horas extra no supera el 30 %.	Bajo – Demandas o controversias contractuales menores que no superan los 1.5 millones de pesos.

Análisis de RTO y RPO de cada proceso

Procesos de negocio	RTO	RPO	Prioridad
Soporte y atención al cliente	4 horas	15 minutos (base de datos de clientes)	1 (crítico)
Desarrollo y mantenimiento de software	2 horas (repositorios), 4 horas (CI/CD)	0 horas (código fuente), 1 hora (artefactos de CI)	2 (muy alto)
Gestión de datos personales y privacidad	48 horas (disponibilidad)	24 horas (cambios en registros)	3 (medio)
Gestión financiera y contractual	24 horas (facturación), 48 horas (contratos)	24 horas (documentos)	4 (bajo)

4. EVALUACIÓN DE ESCENARIOS Y ESTRATEGIAS

Con base en el Análisis de Impacto al Negocio, se ordenan los escenarios de riesgo posibles por su criticidad para NovaTech. Así mismo se establecen las estrategias para cada uno

Escenario 1: Ataque Informático (malware, ransomware, etc.)

- **Tiempo Máximo Tolerable (RTO):** 4 horas
- **Estrategias de Continuidad:**
 1. Activar un entorno alternativo del CRM en otra región del proveedor cloud (failover preconfigurado).
 2. Activación del Equipo de Respuesta a Incidentes.
 3. Accionar medidas de contención técnica, (aislamiento de sistemas comprometidos, revocación de credenciales).
 4. Notificación del incidente a clientes y contratistas con tiempos esperados mientras se restablece el sistema principal.

Escenario 2: Falla de infraestructura

- **Tiempo Máximo Tolerable (RTO):** 2 horas (repositorios), 4 horas (CI/CD)
- **Estrategias de Continuidad:**
 1. Recuperación de Infraestructura en la nube (AWS).
 2. Habilitar canales de comunicación de contingencia con clientes (correo electrónico directo, formulario web estático en sitio alternativo)
 3. Recuperación de copias de seguridad de las bases de datos.

Escenario 3: Pérdida de datos

- **Tiempo Máximo Tolerable (RTO):** 48 horas (disponibilidad)
- **Estrategias de Continuidad:**
 1. Restauración de copias de seguridad de las bases de datos.
 2. Identificar y corregir problemas en base de datos.
 3. Análisis de Integridad de los datos recuperados

5. ROLES Y RESPONSABILIDADES

Rol	Área	Responsabilidades
Comité de Crisis	Dirección General, Responsable de Seguridad de la Información (RSI), Líderes de Área	Declarar formalmente el incidente y activar el BCP. Aprobar desembolsos de emergencia, gestionar la comunicación externa de alto nivel y las notificaciones regulatorias.
Coordinador de Continuidad	RSI	Dirigir la ejecución del BCP, centralizar la información de estado, coordinar a los equipos de recuperación y reportar el avance al Comité cada 30 minutos.
Responsable de Atención al Cliente	Depto. Atención a Clientes	Activar el CRM alternativo, coordinar la comunicación con clientes y monitorear la restauración del servicio de soporte.
Responsable de Infraestructura TI	Depto. Infraestructura Tecnológica	Ejecutar las tareas de contención técnica y coordinarse con los proveedores cloud. Proveer acceso a los entornos alternos y copias de seguridad.
Encargado de Comunicación	Marketing / RR.HH.	Elaborar y difundir los comunicados internos y externos bajo la aprobación del Comité de Crisis.
Oficial de Protección de Datos (DPO)	Legal / Administración	Evaluar el impacto en datos personales, determinar la obligación de notificar a las autoridades (LFPDPPP) y a los titulares, y asesorar en la comunicación de crisis.

6. PLAN DE CONTINUIDAD DEL NEGOCIO (BCP)

Acciones durante el incidente

1. De 0 a 1 hora

- (0:00) Cualquier empleado que detecte un comportamiento extraño lo reporta inmediatamente al Responsable de Infraestructura TI y al RSI.
- (0:10 - 0:20) Infraestructura TI inicia una evaluación para confirmar el incidente y determinar el alcance. Si se confirma que afecta activos críticos, se convoca al Comité de Crisis.
- (0:20 - 0:30) El Comité de Crisis declara el inicio del incidente y ordena la activación del BCP. Se notifica al Coordinador de Continuidad. Se envía un comunicado interno breve a los líderes de área indicando la situación y las primeras instrucciones
- (0:30 - 1:00) Infraestructura TI, junto al Coordinador, aplica las medidas de contención técnica: aislamiento de sistemas comprometidos, revocación de credenciales, bloqueo de accesos externos no autorizados.

2. De 1 a 4 horas

- (1:00 - 1:30) El responsable del proceso ejecuta las estrategias definidas correspondientes, la activación del entorno alternativo y verifica su funcionalidad. Informa al equipo sobre los canales de contingencia.
- (1:30 - 2:00) Los sistemas alternos se encuentran en funcionamiento, cumpliendo con la restauración de procesos
- (2:00 - 3:00) Se publica un comunicado externo dirigido a clientes (si aplica), explicando la naturaleza del incidente.
- (3:00 - 4:00) Meta: El proceso debe estar funcionando, cumpliendo el RTO. De no ser así, el Comité escala la situación y evalúa la activación de recursos adicionales o proveedores.

3. De 4 a 48 horas

- (24:00) El DPO determina si hay evidencia de fuga de datos personales de clientes o empleados y presenta las notificaciones formales a la autoridad de protección de datos y a los titulares afectados de ser necesario.
- (24:00 - 48:00) Se realiza la migración ordenada de las operaciones de vuelta a los sistemas principales, previa validación de seguridad. Se desactivan los entornos de contingencia. Se realiza un análisis en busca de riesgos residuales.
- Al restaurar: Convocar a una reunión de análisis post-incidente con todos los roles involucrados. Documentar la cronología completa, las causas raíz, la efectividad de las estrategias de continuidad y las desviaciones en los RTO. Actualizar el BCP y el DRP con las lecciones aprendidas.

7. PLAN DE RECUPERACIÓN ANTE DESASTRES (DRP)

Parámetros:

A partir del análisis BIA, se consideran los mismos parámetros, con un RTO de 4 horas y un RPO de 15 minutos.

Estrategias Técnicas de Recuperación:

1. Sitio caliente en la nube, con Backups incrementales cada 15 min y snapshots diarios.
2. Despliegue en Zona de Recuperación Aislada (Red Restringida)
3. Reaprovisionamiento Automatizado como Código
4. Replicación Transaccional y Punto de Recuperación Granular
5. Monitorear la efectividad de las medidas aplicadas

8. MANTENIMIENTO Y PRUEBAS CONSTANTES DEL PLAN

Se establecen simulacros y pruebas del plan con el propósito de capacitar al personal ante incidentes y evaluar la efectividad de los métodos.

El BCP será probado con un simulacro de alguno de los escenarios descritos, será realizado en horas de baja actividad al menos una vez al año.

El DRP es validado mediante el desarrollo de un ejercicio de prueba de los planes y la tecnología complementaria. Éste se lleva a cabo al menos dos veces al año o luego de cambios significativos en la tecnología.

De forma adicional, el BIA deberá mantenerse actualizado, analizando los impactos de estos procesos en las distintas áreas para su priorización posterior.